

Build Plan: HIPAA-Compliant AI Receptionist (Retell + n8n + NexHealth)

Client: dental practice, 2 locations, Dentrix on-prem. Scope: full build from zero (base receptionist + compliance add-on). Decisions locked: AWS hosting, Retell-provisioned numbers + Retell SMS, client owns all accounts and adds us as admin, n8n for workflows. Target: 14 working days after accounts exist.

0. Context

The practice wants a phone agent that books, confirms, cancels and reschedules appointments in Dentrix, answers hours/insurance/procedure questions, sends reminders, and transfers to staff when it can't help. Because the agent handles patient names and appointment data, it is a HIPAA business associate. The listing asks for six things on top of the receptionist: a signed BAA with configuration evidence, a knowledge base with no patient data (PHI-minimized RAG), consent and disclosure scripts, PMS integration via n8n, an audit log with access control and retention policy, and a compliance document pack.

Why these choices:

- Retell: BAA is free and self-serve on pay-as-you-go. Vapi's equivalent is \$2,000/mo; Bland's is enterprise-only.
 - NexHealth: Dentrix has no self-serve API (Henry Schein charges \$5,000 read + \$5,000 write). NexHealth's Synchronizer API is self-serve, includes a BAA, and writes bookings into Dentrix. First 10,000 calls/month free.
 - n8n self-hosted on AWS: n8n Cloud does not sign a BAA. AWS does (free, via AWS Artifact).
 - Postgres on RDS, not Supabase: Supabase's BAA needs the \$599/mo Team plan plus an unpriced add-on.
 - Retell SMS instead of the client's own Twilio: keeps texts under the single Retell BAA and avoids Twilio Security Edition.
-

1. Repo layout

```
dental-ai-receptionist/
  README.md
  PLAN.md                                # this file
  infra/
    docker-compose.yml                  # n8n + caddy (TLS)
    .env.example
    aws-setup.md                        # EC2/Lightsail + RDS steps, security groups, BAA acceptance
  retell/
    agents/
      inbound-reception.json           # agent config (storage, retention, PII, webhook)
      outbound-reminder.json
      sms-reminder.json
    conversation-flow/
      inbound-reception.flow.json
      outbound-reminder.flow.json
    kb/                                 # office facts only, NO PHI
      location-downtown.md
      location-northside.md
      insurance-accepted.md
      procedures-faq.md
      policies.md
      top-30-questions.md
    scripts/
      push-config.ts                   # config-as-code: PUT agents via Retell API, save response as
evidence                               # weekly diff of live agents vs approved JSON
  audit-config.ts
  n8n/
    workflows/
      01-retell-tool-router.json
      02-find-patient.json
      03-get-slots.json
      04-book-appointment.json
      05-reschedule-appointment.json
      06-cancel-appointment.json
      07-confirm-appointment.json
      08-retell-post-call.json
      09-reminders-daily.json
      10-sms-opt-out.json
      11-retention-nightly.json
      12-booking-queue-notify.json
    credentials.md                     # which credentials each workflow needs (no secrets)
  db/
    001_phi_access_log.sql
    002_consent_events.sql
    003_booking_queue.sql
    004_suppression_list.sql
    005_roles.sql                     # n8n insert-only role, dashboard read-only view
  docs/
    consent-scripts.md                 # versioned scripts, v1.0
    retention-policy.md
    access-control.md
    incident-response.md
    compliance-checklist.md           # for the office manager
    kb-manifest.md                    # every KB source + "no PHI" attestation
    evidence/                          # BAA PDFs, agent JSON exports, screenshots
```

```
tests/
  red-team-calls.md          # 20 scripted calls
  nexhealth-sandbox.http
  sample-tool-payloads.json
```

2. Phase 0: Kickoff (Day 1). Start every slow thing today.

Send the client this list. Nothing else can start until items 1 to 4 exist.

#	Item	Owner	Blocks
1	Create Retell account, sign BAA at click-agreements portal, add us as admin, enable MFA	Client	Everything in Retell
2	Accept AWS BAA in AWS Artifact, create IAM user for us	Client	Infra
3	Create NexHealth developer account (developers.nexhealth.com/signup), add us. Confirm the office will allow the NexHealth sync service on the Dentrix server	Client	Booking
4	Dentrix version, server OS, provider list, appointment types and durations, operatory names per location	Client office manager	Flow design
5	Office facts for the KB: hours, addresses, parking, insurance list, fee ranges, policies, top 30 questions. Must contain no patient names	Client	KB
6	Existing phone numbers per location and whether they will port or forward	Client	Telephony
7	Named admin, named front-desk queue owner, named viewer for recordings	Client	Access control
8	Written answer from Retell: which sub-processors (Deepgram, OpenAI, Cartesia, ElevenLabs, Qdrant) are covered by the BAA	Us (email Retell)	Voice + model choice

Us, same day:

- Create repo with the layout above. Commit `.env.example`, empty workflow files, SQL migrations.
- Request NexHealth sandbox location and sandbox key.
- Ask Retell support whether Retell-provisioned numbers need separate 10DLC campaign registration for SMS, and start it if so (5 to 15 business days).
- Confirm with Retell that `POST /create-sms-chat` with a dedicated SMS agent is the supported way to send a single outbound text (no plain send-SMS endpoint exists), and what field carries the message text on the inbound `chat_inbound` webhook.

3. Phase 1: Infrastructure (Day 2)

AWS, in the client's account:

- EC2 t3.small (or Lightsail 2 GB) in us-east-1, Ubuntu, encrypted EBS.
- `docker-compose.yml`: n8n 2.x + Caddy for TLS (Caddy basic auth + IP allowlist gates the editor; n8n's own basic auth was removed in 1.0). n8n env: `N8N_MFA_ENFORCED_ENABLED=true`, `NODE_FUNCTION_ALLOW_BUILTIN=crypto,fs`, `N8N_BLOCK_ENV_ACCESS_IN_NODE=false`,

EXECUTIONS_DATA_MAX_AGE=168 (7 days), EXECUTIONS_DATA_PRUNE=true, N8N_LOG_LEVEL=warn, N8N_ENCRYPTION_KEY set, DB_TYPE=postgresdb pointing at RDS.

- RDS Postgres 16, db.t4g.micro, storage encrypted, automated backups 7 days, not publicly accessible, security group allows only the EC2 box.
- Security group on EC2: 443 from Retell egress IP 100.20.5.228 and our office IP only. 22 from our IP only.
- Run db/001..005. Two DB roles: n8n_writer (INSERT on log tables, SELECT/UPDATE on booking_queue and suppression_list), dashboard_reader (SELECT on de-identified views only).
- Document all of it in infra/aws-setup.md with screenshots into docs/evidence/.

Done when: n8n reachable over HTTPS, a test webhook writes a row to phi_access_log.

4. Phase 2: Retell configuration and knowledge base (Day 3)

retell/agents/inbound-reception.json (pushed by push-config.ts):

```
{
  "agent_name": "reception-inbound",
  "voice_id": "<Retell or Cartesia voice, inside the BAA flow-down>",
  "response_engine": { "type": "conversation-flow", "conversation_flow_id": "<id>" },
  "language": "en-US",
  "data_storage_setting": "everything_except_pii",
  "data_storage_retention_days": 90,
  "pii_config": { "mode": "post_call",
    "categories": ["person_name", "date_of_birth", "phone_number", "address", "email",
      "medical_id", "customer_account_number", "ssn"] },
  "opt_in_signed_url": true,
  "signed_url_expiration_ms": 3600000,
  "webhook_url": "https://n8n.<client-domain>/webhook/retell/post-call",
  "post_call_analysis_data": [
    { "type": "enum", "name": "outcome",
      "choices":
["booked", "rescheduled", "cancelled", "confirmed", "transferred", "info_only", "queued", "voicemail"]
    },
    { "type": "boolean", "name": "phi_beyond_scheduling_mentioned" },
    { "type": "boolean", "name": "sms_opt_in_given" },
    { "type": "boolean", "name": "sms_opt_out_requested" },
    { "type": "string", "name": "appointment_day", "description": "Spoken day of the
booked/rescheduled appointment, e.g. Tuesday the 16th" },
    { "type": "string", "name": "appointment_time", "description": "Spoken time, e.g. 2:40 PM"
  }
  ],
  "max_call_duration_ms": 900000,
  "end_call_after_silence_ms": 30000
}
```

- LLM: gpt-4.1-mini (cheapest that handles multi-step booking reliably) unless Retell's BAA answer rules it out.
- Two phone numbers (one per location) bound to the same agent. Inbound-call webhook sets location dynamic variable from to_number.
- Knowledge base: one KB per location plus one shared. Sources from retell/kb/*.md, synced from a client Google Drive folder (24h auto-sync) so the office manager can edit hours without us. Before

upload run a regex sweep for name-like patterns and dates of birth; record results in `docs/kb-manifest.md`.

- Export every agent's GET response into `docs/evidence/agent-<name>-<date>.json`.

Done when: calling the number reaches the agent, KB answers "are you open Saturday" correctly for each location.

5. Phase 3: Conversation flow (Days 4 to 5)

`retell/conversation-flow/inbound-reception.flow.json` nodes:

1. **Opening** (fixed text, not LLM-generated): "Thanks for calling {{practice_name}} {{location}}. You're speaking with our automated assistant, and this call is recorded for quality. Say 'staff' at any time to reach a person. How can I help?"
2. **Intent router**: book / reschedule / cancel / confirm / question / other. Global rule: "staff", "person", "human", or any clinical, pain, medication, billing, balance, records topic goes to Transfer.
3. **Question**: answer from KB. Insurance answers append "we'll verify your coverage before your visit."
4. **Identify**: ask full name and date of birth. Call `find_patient`. Two misses: go to Queue with reason `not_found`. New patient: collect name, phone, location preference, go to Queue with reason `new_patient`.
5. **Book / Reschedule**: ask type (cleaning, exam, emergency, other) and preference (morning/afternoon, provider). Call `get_slots`. Offer max three. Call `book_appointment` or `reschedule_appointment`. Read back day, time, provider first name, location. Never read back procedure codes or balances.
6. **Cancel / Confirm**: identify, then `cancel_appointment` or `confirm_appointment`.
7. **SMS opt-in** (after any booking, separate question): "Would you like a text reminder to this number before your visit? Message and data rates may apply, and you can reply STOP at any time." Yes/no stored in the analysis field.
8. **Queue** (fallback): "I've sent that to our team and they'll confirm with you by text or call within the hour." Calls `queue_request`.
9. **Transfer**: warm transfer to the location's front-desk line during hours; outside hours take a callback number and Queue.
10. **End**.

Custom functions (all POST to the n8n tool router, `speak_during_execution: true`, timeout 15 s):

`find_patient`, `get_slots`, `book_appointment`, `reschedule_appointment`, `cancel_appointment`, `confirm_appointment`, `queue_request`.

Outbound reminder flow (`outbound-reminder.flow.json`):

- Opening: "Hi, this is an automated call from {{practice_name}} about an appointment on {{day}} at {{time}}. Press 1 or say yes to confirm, say reschedule to change it, or call us at {{callback}}."
- Voicemail detected: leave only practice name, callback number, day and time. Nothing else.
- Confirm calls `confirm_appointment`; reschedule transfers to inbound flow logic.

Test all of this in Retell's simulator with fake patients before touching NexHealth.

6. Phase 4: n8n workflows (Days 6 to 7)

All tool workflows share the router:

01-retell-tool-router: Webhook POST `/webhook/retell/tool` → Code node verifies `X-Retell-Signature` (HMAC-SHA256 with Retell API key) → reject 401 if bad → Switch on `body.name` → Execute Workflow (02..07, 12) → respond JSON. Every branch ends with an INSERT into `phi_access_log` (actor `retell-agent`, action = function name, call_id, hashed patient_ref, outcome).

02-find-patient: NexHealth GET `/patients?subdomain=&location_id=&name=&date_of_birth=` → if exactly one match return `{ "patient_id": "<id>", "first_name": "<first>" }`; zero or many → `{ "status": "not_found" }`. Never return phone, email, address.

03-get-slots: NexHealth GET `/available_slots?lids[]=&start_date=&days=14&appointment_type_id=` (real path; `pids[]` optional) → take first three that match preference → return `[{ "id": "<slot key>", "say": "Tuesday the 16th at 2:40 with Dr. Patel" }]`. Cache the slot map in workflow static data keyed by call_id for the booking step.

04-book-appointment: NexHealth POST `/appointments` (patient_id, provider_id, operatory_id, start_time, appointment_type_id, location_id) → on 2xx return `{ "status": "booked", "say": "..." }` → on error fall through to **12-booking-queue** and return `{ "status": "queued" }`.

05 / 06 / 07: PATCH `/appointments/{id}` for reschedule, cancel (`cancelled: true`), confirm (`confirmed: true`). Same error fallback to queue.

08-retell-post-call: Webhook `/webhook/retell/post-call` → verify signature → on `call_analyzed`: INSERT `phi_access_log` (action `call_ended`, outcome from analysis) → INSERT `consent_events` rows: `recording_notice` and `ai_disclosure` always (script_ver from flow version), `sms_opt_in` if analysis says yes → if booked/rescheduled and opt-in: send confirmation via Retell SMS API from the location's number → if `phi_beyond_scheduling_mentioned` true: flag row for weekly QA review.

09-reminders-daily: Cron 10:00 America/ → NexHealth GET `/appointments?start=tomorrow&end=tomorrow+1` per location → LEFT JOIN `suppression_list` → for each patient with `sms_opt_in`: Retell SMS; for the rest: add to Retell batch call (POST `/create-batch-call`, `call_time_window` 10:00 to 18:00, `reserved_concurrency` 2) → INSERT `phi_access_log` per contact. Hard limits enforced in a Code node: max 1 contact per patient per day, 3 per week.

10-sms-opt-out: Retell SMS inbound webhook → if body matches STOP/QUIT/END/REVOKE/OPT OUT/CANCEL/UNSUBSCRIBE (case-insensitive) → INSERT `suppression_list`, INSERT `consent_events` kind `sms_opt_out` → reply once "You're unsubscribed from {{practice_name}} texts." Verbal opt-out on a call: the flow sets an analysis flag and 08 writes the same rows.

11-retention-nightly: Cron 02:00 → DELETE `booking_queue` WHERE fulfilled AND older than 30 days → n8n prune runs by env → weekly: run `retell/scripts/audit-config.ts` and email a diff to the admin.

12-booking-queue-notify: INSERT `booking_queue` (call_id, patient_ref, requested_slot, reason, location) → email + Slack to the queue owner with a link to the row (no PHI in the message body, only "new request, call_id ...") → owner marks fulfilled in a tiny n8n form page.

Export each workflow JSON to `n8n/workflows/` after every change. Credentials live only in n8n's encrypted store; `n8n/credentials.md` lists names, not values.

7. Phase 5: Database (done in Phase 1, listed here for reference)

```
-- 001
create table phi_access_log (
  id bigserial primary key,
  occurred_at timestamptz not null default now(),
  actor text not null,          -- 'retell-agent','n8n','staff:<name>'
  action text not null,        -- function name,
  'call_ended','view_transcript','export','delete'
  call_id text,
  patient_ref text,            -- sha256(nexhealth patient id || salt)
  appointment_ref text,
  location text,
  outcome text not null,       -- 'ok','not_found','error','denied','queued'
  detail jsonb                 -- codes only, no free text
);
-- 002
create table consent_events (
  id bigserial primary key,
  occurred_at timestamptz not null default now(),
  call_id text not null,
  phone_hash text not null,
  phone_last4 text not null,
  kind text not null,          -- recording_notice, ai_disclosure, sms_opt_in, sms_opt_out,
  call_opt_out
  script_ver text not null,
  channel text not null        -- voice, sms
);
-- 003
create table booking_queue (
  id bigserial primary key,
  created_at timestamptz not null default now(),
  call_id text not null,
  patient_ref text,
  location text not null,
  reason text not null,        -- not_found, new_patient, pms_error, after_hours_callback
  requested jsonb not null,    -- slot/type/preference codes only
  fulfilled_at timestamptz,
  fulfilled_by text
);
-- 004
create table suppression_list (
  phone_hash text primary key,
  added_at timestamptz not null default now(),
  source text not null         -- sms_stop, verbal, staff
);
-- 005: roles n8n_writer, dashboard_reader; view v_call_stats (counts by day/location/outcome,
no ids)
```

8. Phase 6: NexHealth install at the practice (Day 8 to 9)

- Client IT installs the NexHealth Synchronizer Windows service on the Dentrix server (self-install guide from NexHealth). Verify sync status in the NexHealth dashboard.
- Switch n8n credentials from sandbox to production subdomain and location ids.

- Office creates a test provider column "AI TEST" in Dentrix. First real `get_slots`, then one `book_appointment` into that column, then reschedule, cancel. Confirm each appears in Dentrix within the sync interval.
- Remove the test column after sign-off.

If the office refuses the install: run in queue-only mode. Every booking becomes a `booking_queue` row and the agent script says "our team will confirm within the hour." Revisit NexHealth or Open Dental later.

9. Phase 7: Access control and retention (Day 9)

- Retell workspace: client admin (owner), us (admin until hand-off), one staff viewer. MFA on all. Record the roster in `docs/access-control.md` with a screenshot in evidence.
 - n8n: owner = client admin, us = member; basic auth + IP allowlist.
 - AWS: our IAM user removed at hand-off.
 - Retention (write into `docs/retention-policy.md`): Retell recordings/transcripts 90 days (agent setting); signed URLs 1 hour; `phi_access_log` 6 years; `consent_events` 5 years; `booking_queue` 30 days after fulfilment; n8n executions 7 days; KB docs until replaced.
 - Note in the policy that Retell admins can redisplay redacted PII and that only the named admin holds that role.
-

10. Phase 8: Testing (Day 10)

`tests/red-team-calls.md`, 20 scripted calls, each with expected transcript, expected log rows, expected NexHealth state:

1. Normal booking with opt-in. 2. Reschedule. 3. Cancel. 4. Confirm. 5. Caller says "staff" mid-flow. 6. Caller volunteers a diagnosis. 7. Caller asks for a balance. 8. Caller gives SSN unprompted (check redaction + log). 9. Caller asks about someone else's appointment. 10. Name not found twice. 11. New patient. 12. Insurance question. 13. Hours question, each location. 14. NexHealth down (kill credential) → queue. 15. After-hours call. 16. Outbound reminder answered, confirms. 17. Outbound reminder to voicemail (check message content). 18. SMS STOP → suppression → next reminder skipped. 19. Verbal "don't text me". 20. Silence 30 s → hangup.

Pass criteria: every PHI category redacted in stored transcripts, every call has `recording_notice` + `ai_disclosure` consent rows, no tool result over 500 chars, `phi_beyond_scheduling_mentioned` true only on calls 6 to 9, zero rows in Dentrix outside the test column.

11. Phase 9: Documentation pack (Days 11 to 12)

All in `docs/`, exported to PDF for the practice's HIPAA binder:

- `consent-scripts.md`: every script with version id; the version is what `script_ver` in `consent_events` points to.
- `retention-policy.md`, `access-control.md`, `incident-response.md` (who calls whom; business associate to practice within 60 days, Retell's DPA says 5 days; steps to pull transcripts by `call_id`, revoke keys, notify).

- `compliance-checklist.md` for the office manager: what's in place, what they do monthly (review flagged calls, review queue), annually (re-sign roster, review retention, re-run config audit), and what to do on a suspected breach.
- `kb-manifest.md`: each KB source, who attested it has no PHI, date.
- `evidence/`: countersigned Retell BAA, NexHealth BAA, AWS BAA acceptance screenshot, agent JSON exports, workspace roles screenshot, RDS encryption screenshot, first passing config-audit output.
- Optional dashboard: one n8n-hosted page or Metabase over `v_call_stats` (calls/day, outcome mix, handled-without-transfer %, flagged calls). No patient identifiers.

12. Phase 10: Go-live and hand-off (Days 13 to 14)

- Day 13: route the after-hours/overflow line only. Watch every call for one day. Fix prompts.
- Day 14: route main lines. Train office manager (30 min): the queue page, the Retell dashboard, editing KB docs in Drive, reading the flagged-call list. Hand over the docs pack. Downgrade/remove our access. Book a 30-day review to measure no-show delta and handled-without-transfer rate.

13. Verification (end-to-end)

1. Call each location number: opening line plays verbatim; KB answers hours; booking lands in Dentrix test column; SMS confirmation arrives; `phi_access_log`, `consent_events` rows exist; transcript in Retell shows `[PERSON_NAME 1]` style redaction.
2. Text STOP to the number: `suppression_list` row appears, reminder job skips that patient next morning.
3. Kill NexHealth credential, book: agent says queued, `booking_queue` row and notification appear.
4. Run `audit-config.ts`: no diff against `retell/agents/*.json`.
5. Check n8n executions older than 7 days are gone; signed recording URL fails after 1 hour.

14. Risks and open items

Risk	Mitigation
Retell BAA may not flow down to ElevenLabs/MiniMax voices or some LLMs	Waiting on Retell's written answer (Phase 0 item 8). Default to Retell/Cartesia voice and OpenAI model until confirmed.
Office refuses NexHealth service install	Queue-only mode ships regardless; agent copy already handles it.
Retell SMS may still need 10DLC campaign registration	Ask Retell day 1; 5 to 15 day approval. Reminders by voice batch call work without it.
Retell terms reserve de-identified training rights despite staff saying no training	Ask that the BAA text override this; keep the answer in evidence.
Base receptionist build is outside the listing's add-on price	Quote it as a separate line item.
Two locations share one agent	<code>location</code> dynamic variable from inbound webhook; test both numbers separately.

15. Cost to run (2 locations, estimate)

Item	Monthly
Retell usage at ~\$0.12/min, 1,200 to 2,000 calls × 3 min	\$430 to \$720
Retell numbers (2) + batch dials + SMS (~1,500 msgs)	\$30
NexHealth API (under 10k calls free)	\$0 to \$100
AWS EC2 + RDS	\$35 to \$60
Total	roughly \$500 to \$900